

Overview of standards and the regulatory framework

This morning, the MERIDIAN group's NIS 2 applicability was characterized, and an uncomfortable truth emerged: the directive is only one piece of the puzzle. The GDPR already applies, the Santé subsidiary carries a certified-hosting requirement, Territoires lives under the RGS, and nobody on the Executive Committee can say which of these texts takes precedence over the others. This lecture provides the map: who writes these texts, which ones are binding, which ones are chosen, and how a CISO uses them to build a single security approach instead of four parallel compliance efforts.

✓ From Thursday's question to the map of the landscape

What is imposed: the law

GDPR, NIS 2

What is chosen: the standard

ISO/IEC 27001, certifiable
by a third party

What advises: the guides

ANSSI guides, NIST CSF

Session objectives

By the end of this lecture:

- **Define** what a security framework is and distinguish its four families: standards, guides, regulations and directives
- **Position** ISO/IEC 27001 within this landscape: what the standard requires, what its certification attests, and what it does not attest
- **Map** the regulatory framework applicable to each MERIDIAN subsidiary, including what is still in motion
- **Explain** the role of ANSSI's guides, from the hygiene guide to the ReCyF, their actual legal force, and position the NIST CSF against them
- **Prepare** the afternoon's decision: the reasoned choice of a framework for the group

Prerequisites

- The NIS 2 characterization of the subsidiaries done at this morning's "CISO's briefing": it is reused as is, not redone.
- The session 2 mapping (business assets, supporting assets, DICT needs): it is what makes the choice of a framework possible, and this lecture shows why.
- The regulatory context set out in session 1 for each subsidiary, and the notion of regulatory compliance seen in the session 1 quiz.

Why this map, and why now

One figure to frame the scale of the subject: according to the CESIN barometer published in 2026, 85 % of companies reported being affected in 2025 by at least one cyber regulation. Regulation is no longer a specialist topic, it is a CISO's normal working environment. And the MERIDIAN group is the perfect illustration: four subsidiaries, four different regulatory exposures, one budget and one team. Without a map, each subsidiary handles "its" compliance in its own corner, requirements overlap, gaps contradict one another, and the group pays three times for the same control. The map built in this lecture will be converted this very afternoon into a decision: which single framework serves as the group's backbone.

85%

OF COMPANIES AFFECTED BY
AT LEAST ONE CYBER
REGULATION IN 2025

CESIN / OpinionWay, barometer published
in 2026

9%

OF EU IT INVESTMENT
DEVOTED TO INFORMATION
SECURITY IN 2023

ENISA, NIS Investments report published
in 2024

1 000

ORGANIZATIONS CERTIFIED
TO ISO/IEC 27001 IN
FRANCE AT THE END OF
2023, APPROXIMATELY

AFNOR, based on the ISO Survey

✓ A security framework: a list of requirements that binds

First, the word the session title uses, because it is used everywhere and defined nowhere. The problem it answers was experienced in session 2: when the Santé subsidiary handed in its 120-line “mapping”, there was no way to say whether it was good or insufficient, for lack of a yardstick. Security without a yardstick produces battles of opinion: the provider finds its work sufficient, the auditor finds it patchy, and management decides on charisma. A **security framework**, quite simply, is that yardstick: a document that lists security requirements or controls, with a defined scope of application, against which a system or an organization can be assessed and declared “compliant” or “in deviation”, requirement by requirement.

The mechanics are always the same, whatever the framework: a numbered list of requirements, a scope (who and what it applies to), and a control mode (who checks, how, and with what consequences). What the framework never does: secure anything by itself. A requirement ticked in a table has never stopped ransomware; it is the control deployed behind the tick box that protects, and the deviation between the box and reality is exactly what an audit will go looking for in session 4.

Where professionals get lost is that four very different families of documents play this yardstick role, and they do not bind in the same way. Here is the map, and it is worth memorizing:

Family	Who writes it	Force	Who checks	Examples
Voluntary standard	Standardization bodies (ISO/IEC, with national institutes such as AFNOR)	None by default: it binds whoever chooses to comply with it, or whoever has it imposed by a client through contract	A third-party certification body, if the certificate is sought	ISO/IEC 27001:2022, ISO/IEC 27002:2022
Authority guide	A national authority (ANSSI in France, NIST in the United States)	Recommendation: no obligation, but a quasi-official reference that a judge, a client or an insurer can invoke	Nobody, as long as no legal text makes it enforceable	Guide d'hygiène informatique, EBIOS RM and mapping guides, ReCyF, NIST CSF 2.0
European regulation	The EU legislator	Mandatory and directly applicable in all Member States, without transposition	The authorities designated by the regulation	GDPR, DORA
European directive	The EU legislator	Sets a result; each State transposes it into its national law, which alone creates the obligations	The national authorities, once transposition is done	NIS 2, transposed by the Résilience bill

Ten seconds on the last column on the right: the GDPR and NIS 2 do not have the same status there, and this is not a lawyer's detail. The GDPR is a regulation: it applies as it stands, everywhere, since 2018. NIS 2 is a directive: as long as the French law is not promulgated, it imposes nothing directly on MERIDIAN. This is the nuance that structured this morning's answer, and it comes from that row of the table.

Criterion	The regulation (e.g. GDPR)	The directive (e.g. NIS 2)
Application	Direct and immediate in every Member State, with no intermediate national text.	Indirect: it must be "transposed" by a national law before it becomes applicable.
Purpose	To unify the law with one and the same rule, identical everywhere in Europe.	To harmonize the law by setting common objectives, leaving the choice of means to the States.
Flexibility	Very low: States cannot alter the text, apart from explicitly provided derogations.	High: each country adapts the text to its own legal system and may tighten the rules if it wishes.



What applies without being chosen: MERIDIAN's regulatory foundation

The first reflex of a CISO choosing a framework is not to compare standards: it is to list what already applies. One does not choose to apply the GDPR; one submits to it or ignores it at one's own risk. The regulatory framework is this body of binding texts, European and national, that pre-exists any decision by the group. Here is a tour of MERIDIAN's, subsidiary by subsidiary, starting with what is common to all.

The GDPR, the General Data Protection Regulation, first, because it touches all four subsidiaries: as soon as personal data is processed, and all of them process it, from Santé's patient data to the tens of thousands of accounts on Éducation's portal. It has already been encountered twice in this module: in session 1 under regulatory compliance, and in session 2 because its Article 32 requires appropriate technical and organizational measures, which presupposes knowing one's information system, hence mapping it.

Its sanction regime is worth remembering, because it serves as the point of comparison for everything else: up to 4 % of worldwide annual turnover or 20 million euros for the most serious breaches (Article 83 of the GDPR). And this regime really bites: in 2026, the CNIL imposed a fine of 5 million euros on France Travail, following the breach that had potentially exposed the personal data of 43 million people in 2024. That case was studied in session 2 from the mapping angle; here it is from the regulatory angle, and it is the same file seen from the boardroom.

4 %

OF WORLDWIDE ANNUAL
TURNOVER, OR 20 MILLION
EUROS: THE CAP FOR THE
MOST SERIOUS BREACHES

GDPR, Article 83

€5M

CNIL FINE AGAINST FRANCE
TRAVAIL AFTER THE 2024
BREACH

CNIL, 2025

43M

PEOPLE WHOSE PERSONAL
DATA HAD BEEN POTENTIALLY
EXPOSED

France Travail, 2024

NIS 2, next, this morning's subject. Its name states its purpose: the directive on the security of network and information systems, Network and Information Security, and the 2 marks that it succeeds a first directive of 2016. In one sentence, since the groundwork is done: Santé will very probably be an essential entity, Logistique at least an important one, Territoires depends on a French choice still open, and Éducation is out of scope.

What must be added here is the overview of the obligations that will arrive with the law. There are four of them.

- **Risk management measures.** Article 21 of the directive lists the minimum, from risk analysis to supply chain security.
- **Accountable governance.** Article 20 has these measures approved by the management bodies, which can be held liable and must undergo training. That is what explains the Chief Executive Officer's concern.
- **A three-stage notification of significant incidents:** early warning within 24 hours, notification within 72 hours, final report one month later.
- **Registration with the national authority.**

On sanctions, NIS 2 caps the fine at 2 % of worldwide annual turnover for an essential entity, at 1.4 % for an important one, and adds absolute floors of around ten million euros for the former and seven million for the latter.

24 h

EARLY WARNING OF A
SIGNIFICANT INCIDENT

NIS 2 Directive, three-step notification

72 h

NOTIFICATION OF THE
INCIDENT

NIS 2 Directive, three-step notification

1 month

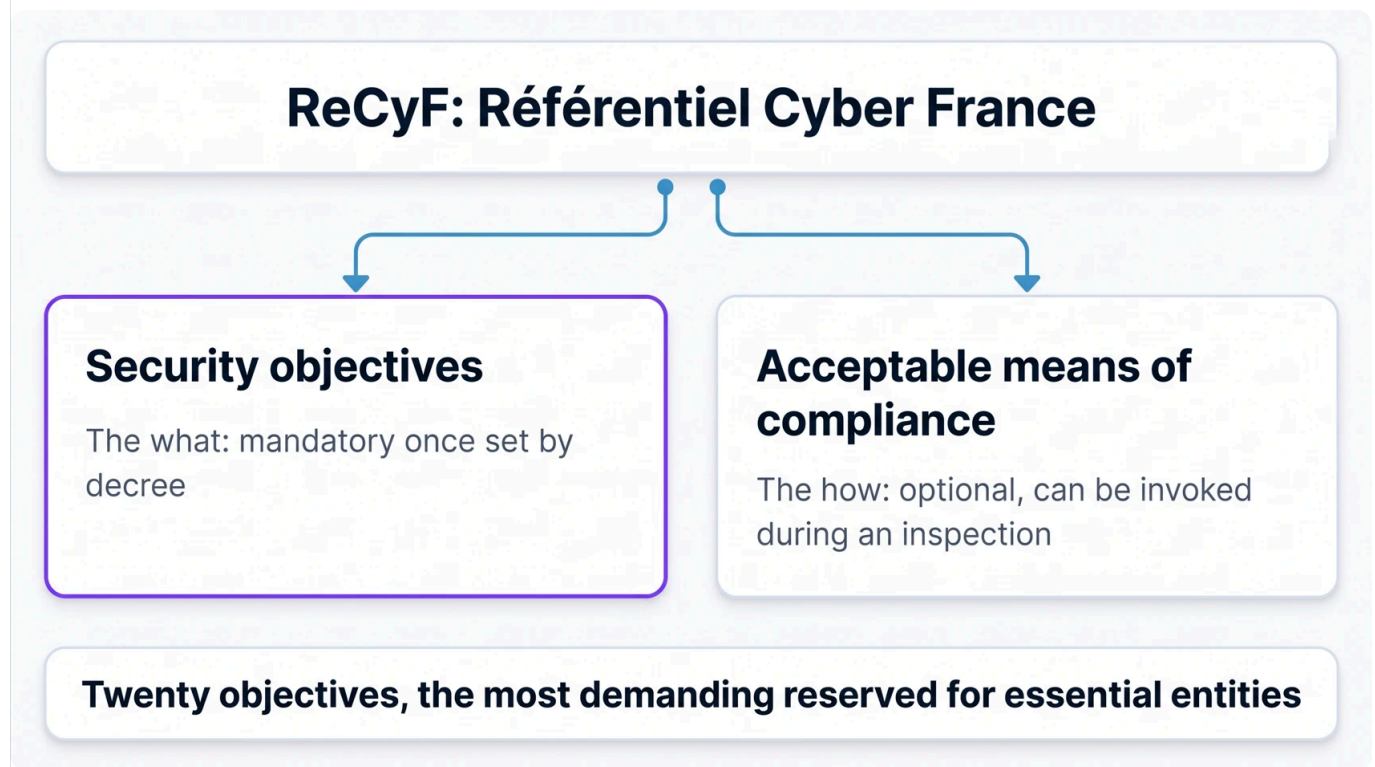
THE FINAL REPORT

NIS 2 Directive, three-step notification

And where does France stand in all this? The Résilience bill, adopted by the Senate on 12 March 2025 and then passed by the special committee of the National Assembly on 10 September 2025, transposes three European texts of December 2022 at once: the NIS 2 and REC directives, the latter on Critical Entities Resilience, and the adaptation to the DORA regulation. While awaiting its promulgation, ANSSI is not sitting idle: since 17 March 2026, it has been circulating the **Référentiel Cyber France (ReCyF)**, a working version of the framework provided for in Article 14 of the bill.

Its construction deserves attention because it reconciles the mandatory and the voluntary in a single document: the ReCyF states security objectives, which answer the question "what?" and will be mandatory once set by

decree, and acceptable means of compliance, which answer the question “how?” and remain optional, but which an entity applying them will be able to rely on in the event of an ANSSI inspection. Twenty objectives in all, and the proportionality seen this morning is found there too: the most demanding objectives, from the sixteenth to the twentieth, apply only to essential entities.



DORA, short for Digital Operational Resilience Act, deserves three sentences, precisely because MERIDIAN is not concerned: it is the counter-example that makes the mechanics clear. Regulation (EU) 2022/2554 on the digital operational resilience of the financial sector has applied since 17 January 2025, directly, without transposition, since it is a regulation. According to ANSSI, it addresses 21 types of entities in the financial sector, where the NIS 2 directive covers the essential and important entities of 18 sectors, and it constitutes a “lex specialis” of NIS 2: for a financial institution, the special text prevails over the general one. No MERIDIAN subsidiary is a financial institution; if the group bought one tomorrow, DORA and not NIS 2 would apply to it. Knowing how to say “this text does not concern us, and here is why” is as much part of the job as the opposite.

The RGS and the HDS, finally, the group's two French sector-specific texts. The référentiel général de sécurité (the French general security framework for public-sector information systems), adopted pursuant to the 2005 ordinance known as the « ordonnance RGS », governs the security of the information systems of administrative authorities in their exchanges with one another and with users; its first and most structuring requirement is to conduct a security authorization (« homologation »), a notion that will be examined closely in session 4. For MERIDIAN Territoires, which operates a citizen services platform for some thirty local authorities, the RGS is the daily contractual environment: its clients are subject to it and pass the requirement on. The context leaves all the less room for improvisation given that, according to a 2023 Cybermalveillance.gouv.fr study, 53 % of French municipalities said they were unprepared for an attack.

The HDS, for its part, is the French certification for health data hosting providers: it targets the provider hosting the data, not the hospital itself. For MERIDIAN Santé, this means two things: checking that its hosting providers are HDS-certified, and knowing that if the group itself hosts health data for third parties, it is the group that will need the certification.

Here is the group's regulatory map, the one to show on Thursday:

Subsidiary	Applies today	Arrives with the Résilience law	Point of vigilance
Santé	GDPR (Art. 32), HDS requirement on hosting providers	NIS 2, very probably as an essential entity	The health sector accounts for 10 % of the incidents brought to ANSSI's attention in 2025
Logistique	GDPR	NIS 2, essential or important depending on the characterization of the activity	The category changes the supervisory regime and the sanction ceiling
Éducation	GDPR	Nothing as things stand (outside the NIS 2 annexes)	Out of scope does not mean out of risk: 45 000 exposed accounts
Territoires	GDPR, RGS (through its clients)	NIS 2 if France includes local administrations	Follow the final text of the law, the answer may change

▼

ISO/IEC 27001: the standard one chooses, and what certification proves

Change of family: after what binds, what is chosen. And first, the notion without which the flagship standard is incomprehensible.

Concept sheet: the ISMS

The problem first. An organization that handles security in fits and starts, a firewall here after an incident, a charter there after an audit, watches its efforts evaporate: controls age, nobody checks that they still work, and every expert's departure takes a piece of the arrangement with it. What is missing is not one more control, it is a system to keep the controls alive. An **information security management system (ISMS)** is exactly that: the organized set of policies, processes, responsibilities and resources through which an organization defines its security objectives, implements the controls to reach them, checks that they work and improves them continuously.

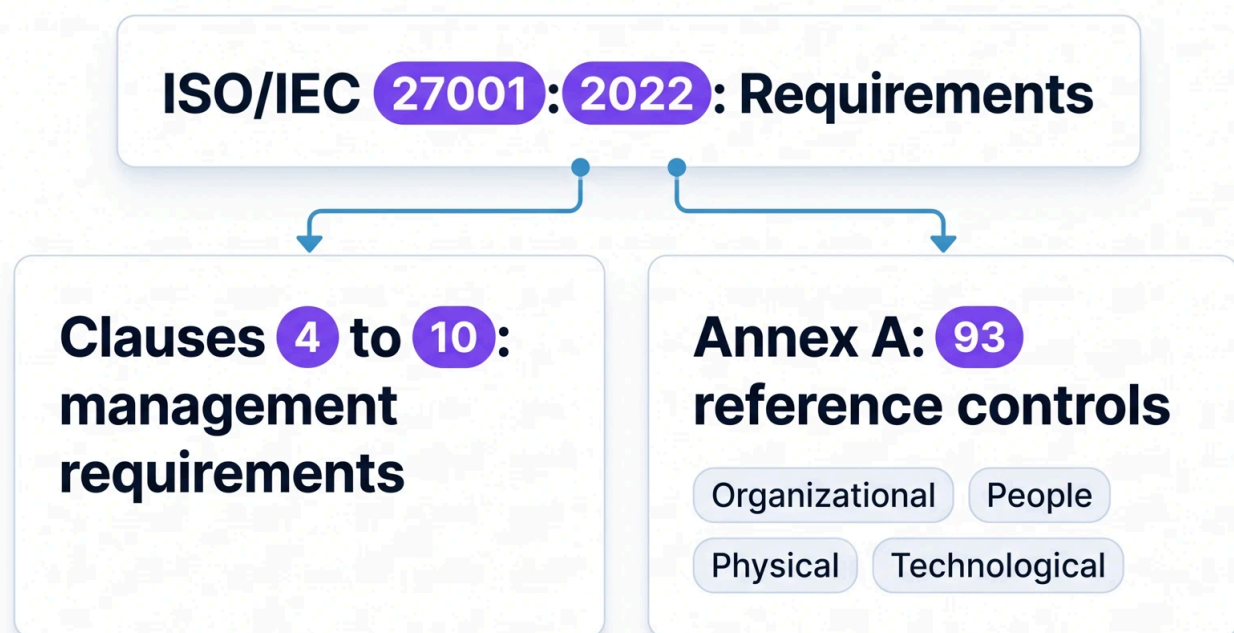
The important word is "management": the ISMS does not describe techniques, it describes the steering loop that governs them, exactly as a quality management system governs production without tightening a single bolt. Its limit is symmetrical: a perfectly documented ISMS can coexist with unpatched servers. The system organizes vigilance, it does not replace it.

The standard, in two blocks

ISO/IEC 27001:2022, whose official title is "Information security management systems - Requirements", is the international standard that defines what an ISMS must include to be judged trustworthy. It will be handled physically this afternoon in the group's GRC tool; here, its outline is enough to decide. The standard is organized in two blocks. The first, clauses 4 to 10, carries the management requirements: context of the organization, leadership, planning, support, operation, performance evaluation, improvement. Their content is not covered today: that is the subject of session 8, when the group decides to build its ISMS.

The second block is an annex, Annex A: a list of reference security controls, 93 controls in the 2022 edition, spread across four themes, organizational, people, physical and technological. These numbers will be verified in the lab: importing the standard into the tool creates exactly this tree.

And the standard has a companion: ISO/IEC 27002:2022, "Information security controls", which takes up these controls and develops them into implementation guidance. The difference lies in the official titles: 27001 states "Requirements", one can be audited against it; 27002 is a collection of annotated controls, to draw on, not to be certified against.



What certification attests, and what it does not

Being ISO/IEC 27001 certified means having demonstrated to a third-party certification body, through an audit, that one's ISMS complies with the requirements of the standard, over a precise scope, the one written on the certificate. Every word of that sentence bounds the proof. It is a third party that attests, not the company itself: that is the value. It is the management system that is audited, not every server: a certificate has never guaranteed the absence of vulnerabilities. And it is a scope that is covered, not the whole organization: a group can be certified on its hosting subsidiary alone and proudly display it.

In France, the exercise remains selective: according to AFNOR, drawing on the ISO Survey, the country had just over a thousand certified organizations at the end of 2023, three times more than in 2019. The momentum was already visible in 2020: increases of 11 % in France and 22 % worldwide that year.

The awkward question, and the one management will ask: "if we get certified, are we in the clear with NIS 2?". The official doctrine comes in two steps, and they seem to contradict each other until the scopes are read. First step, ANSSI's NIS 2 FAQ: « L'obtention d'une certification ISO 27001 ne permet pas, en elle-même, une conformité à NIS 2. » (obtaining ISO 27001 certification does not, in itself, deliver compliance with NIS 2.) The French framework and the standard pursue different objectives, and no general presumption of conformity is granted. Second step, the ReCyF itself: among the acceptable means of compliance for its objective 2, the governance framework objective, is precisely the implementation of an ISMS certified to ISO/IEC 27001:2022, which the entity may rely on « sur les systèmes d'information couverts par la certification » (on the information systems covered by the certification).

Read both again: they say the same thing. Certification proves ONE objective, governance, over ONE scope, that of the certificate. It proves neither network segregation, nor monitoring, nor anything of the other eighteen objectives. A certification is one exhibit in the compliance file, never the file.

The Equifax affair illustrates the gap between displayed compliance and actual security, and it is worth telling with its figures, all established by the US regulator. In 2017, the credit agency Equifax suffered a data breach affecting 147 million people, caused, according to the FTC, by a failure to patch a known vulnerability. The Equifax case, born of that 2017 breach, concluded in 2019 with a settlement of at least 575 million dollars with the FTC, the CFPB and fifty US states. An organization of that size had policies, processes, audits; what was missing was the operational act, patching a server. The lesson cuts both ways: the framework structures, the regulator sanctions, and neither patches in the organization's place.

💡 When an ISO/IEC 27001 certificate is presented, the first thing to read is not the date, it is the scope. "ISMS of the hosting business of the Lyon site" and "ISMS of the group" are two proofs that do not have the same value for the CISO, and the document will not shout the difference.

✓ The ANSSI guides: the authority that advises before it inspects

Between the law that binds and the standard one buys, there exists in France a third way, free of charge and of singular authority: the ANSSI guides. Their legal force is nil, nobody is obliged to follow them; their practical force is considerable, because they state, in the language of the national authority, what it considers the state of the art. A judge, an insurer, a contracting client may ask why they were not followed. Two of them are already intimately known: the mapping guide, from session 2, and EBIOS RM, which returns in session 5. The library is completed with the two that matter for choosing a framework.

The **Guide d'hygiène informatique**, first: « renforcer la sécurité de son système d'information en 42 mesures » (strengthening the security of one's information system in 42 measures), in its version 2 of 2017. It is the basic French general-purpose framework, the answer to "where to start?". Two features make it directly usable as a yardstick: each measure exists in a standard level and a reinforced level, which allows proportionality, and the guide includes its own tracking tool as an annex, an explicit invitation to self-assessment: draw up the state of play, measure by measure, and determine the level reached. It is a sketch, artisanal but real, of what the GRC tool will industrialize this afternoon.

The **mesures cyber préventives prioritaires** next, published in 2023 against a backdrop of heightened threat. In the agency's own words: « L'Agence nationale de la sécurité des systèmes d'information (ANSSI) préconise la mise en œuvre de 5 mesures préventives prioritaires : renforcer l'authentification sur les systèmes d'information ; accroître la supervision de sécurité ; sauvegarder hors-ligne les données et les applications critiques ; établir une liste priorisée des services numériques critiques de l'entité ; s'assurer de l'existence d'un dispositif de gestion de crise adapté à une cyberattaque. » In English, five priority preventive measures:

- strengthen authentication on information systems;
- increase security monitoring;
- back up critical data and applications offline;
- draw up a prioritized list of the entity's critical digital services;
- ensure a crisis management arrangement suited to a cyberattack is in place.

The fourth is recognizable: it is the official anchor of the session 2 Top 5 of critical assets. This mini-framework of five measures shows that a framework need not be a monument: this one fits on a page, targets the emergency, and expires quickly, by design.

That leaves the newest arrival to position, the ReCyF, encountered on the regulatory side: it is a guide by its current status, a non-binding working document, and a future implementing text by destination, since its security objectives will be set by decree. It is living proof that the boundary between the families of the opening table is a boundary of legal status, not of content: the same document can change family when the law takes hold of it.

And where does EBIOS RM fit in all this? One sentence is enough here, as the method has its own session: the guide declares itself compatible with the normative frameworks in force, and its first workshop requires building

the security baseline, that is, the list of applicable frameworks, their state of application and the justified deviations. In other words: the framework chosen today is an input to the session 5 risk analysis. Nothing done this week will need redoing.

✓ NIST CSF: the most famous framework is not the best anchored

One continent is missing from the map, and if this lecture did not cover it, the first English-speaking partner or the first job interview would. NIST, the National Institute of Standards and Technology, is the US standardization institute, the transatlantic counterpart of what AFNOR and ANSSI each partly represent in France. Its Cybersecurity Framework, the NIST CSF, is probably the most cited cybersecurity framework in the world; its current version is 2.0, published on 26 February 2024 under reference NIST CSWP 29, and distributed free of charge.

What it is, first, because its nature explains everything else: neither a requirements standard like ISO/IEC 27001, nor a catalogue of controls like the hygiene guide, but a taxonomy of high-level outcomes, usable by any organization whatever its size, sector or maturity. Its structure comes down to six functions, whose names have become a worldwide professional vocabulary: GOVERN, IDENTIFY, PROTECT, DETECT, RESPOND, RECOVER. Each function breaks down into coded categories; under IDENTIFY, for example, lives asset management, ID.AM, a code that will come back very soon.

And the framework openly refrains from prescribing the how: it describes the outcomes to be achieved and refers, for practices and controls, to online resources that NIST keeps up to date, including official mappings, the Informative References, to other frameworks.



That explains its omnipresence in GRC tools and in every mapping table on the market: a stable, free, non-prescriptive taxonomy is the ideal exchange language BETWEEN frameworks. The observation will be made as early as the tutorial: the group's tool ships two tables that take the NIST CSF as their source, one on version 1.1, the other on the 2.0 published in 2024, and they do not hold the same number of lines; even mappings have a vintage, an idea worth keeping, it will come back in the lab.

Which leaves the question of the day: should MERIDIAN adopt it as its backbone? No, and knowing how to say why matters, because "it is the best known" will be the argument from the other side of the table. The CSF is an authority guide, the third family of the opening table, but from ANOTHER jurisdiction: no European or French text in the landscape gives it the slightest force, tomorrow's NIS 2 compliance will be demonstrated against the objectives of the ReCyF and not against a US framework, and no defensible certification rests on it the way one rests on ISO/IEC 27001.

The criterion that governs the choice of a framework is anchoring, regulatory and evidentiary, never fame: this may be the most useful sentence of this lecture. None of which takes away its two real uses for the group: a common language with English-speaking partners and clients, and a source of mappings when frameworks must be made to talk to each other, which is convenient, as that is this afternoon's exercise.

✓ Choosing: what is at stake this afternoon

The map, recapped, because it governs what follows. Law first: GDPR everywhere, NIS 2 approaching with proportionate categories and objectives, RGS and HDS at sector level; none of this is chosen. The standard next:

ISO/IEC 27001 structures an ISMS and its certification proves, to a third party, governance over a scope. The guides finally: free, graduated, from the 42-measure general-purpose guide to the 5-measure emergency one, with the ReCyF as the bridge towards the mandatory, and the NIST CSF as the international exchange language, precious and without force in France.

Choosing a framework for MERIDIAN will mean arbitrating between these logics: the coming obligation argues for preparing for the ReCyF objectives, the group structure and the proof owed to clients argue for ISO/IEC 27001, the immediate first steps argue for the guides. The mapping table, to be discovered in the tutorial, will show that these options overlap more than they exclude one another, and the lab will import the chosen framework into the GRC tool so that the decision becomes a work plan. At the end of the day, the business case note will carry this choice to senior management. A well-chosen framework is a decision one does not revisit every six months: better to take the time to build it.